

SOC 2 and HIPAA Readiness Self-Assessment

Brooks Security LLC | brooks-security.com

Draft pending review. This is the working draft of the lead-magnet checklist. Graham should review the content before it is treated as final.

This is the readiness self-assessment I work through when I take on a compliance client. It will not pass an audit for you. What it does is show you, honestly, where your gaps are before an auditor finds them. Go through each item and mark it one of three ways:

- **Yes:** in place, written down, and you could show evidence today.
- **Partial:** it exists informally or in one person's head, but it is not documented or not enforced.
- **No:** not in place.

Every Partial and every No is a line item of work between you and a clean report. Most teams are surprised by how many Partials they have. That is normal, and it is the point of doing this before the audit instead of during it.

1. Policies and procedures

The foundation. An auditor reads your policies first, then checks whether you actually do what they say.

- ☐ You have a written information security policy set, not a single generic document.
- ☐ The policies describe how your organization actually operates, not a template you downloaded.
- ☐ Each policy has an owner and a review date, and the reviews actually happen.
- ☐ Employees have read and acknowledged the policies, and you can prove it.
- ☐ You have an acceptable use policy, an access control policy, and a change management policy at minimum.
- ☐ For HIPAA: you have policies covering the Privacy Rule, the Security Rule, and breach notification.

2. Risk analysis

For HIPAA this is required by the Security Rule and is the most common enforcement trigger. For SOC 2 it underpins almost every control decision.

- ☐ You have conducted a formal risk analysis, not just an informal sense of your risks.
- ☐ It identifies where your sensitive data (or protected health information) actually lives, including backups and third parties.
- ☐ Each identified risk has a documented treatment decision: mitigate, accept, transfer, or avoid.
- ☐ The risk analysis is current. It has been updated in the last 12 months or after any major change.
- ☐ You have a risk register that someone owns and reviews.

3. Access control

- ☐ Every user has a unique account. No shared logins.
- ☐ Access is granted on least privilege, and you can explain why each person has what they have.
- ☐ Multi-factor authentication is enforced on email, cloud consoles, and anything holding sensitive data.
- ☐ You run access reviews on a schedule and keep the records.
- ☐ There is a documented process to remove access when someone leaves, and it runs the same day.
- ☐ Administrative and production access is restricted to the people who genuinely need it.

4. Change management

- ☐ Changes to production go through a defined, written process.
- ☐ Code and infrastructure changes are peer reviewed before they ship.
- ☐ Changes are traceable. You can tell who changed what, when, and why.
- ☐ You separate the ability to write a change from the ability to approve and deploy it where it matters.

5. Cloud control implementation

Controls that live only in a document fail audits and fail in real incidents. These should be enforced in your environment.

- ☐ Infrastructure is defined as code (for example Terraform), not clicked together by hand.
- ☐ Security controls are enforced by configuration, not by asking people to remember them.

- ☐ Data is encrypted at rest and in transit, and you can show the configuration that proves it.
- ☐ Logging is centralized, and logs are retained long enough to investigate an incident.
- ☐ You have alerting on the events that actually matter, not just dashboards nobody watches.
- ☐ Backups exist, are encrypted, and you have actually tested a restore.

6. Evidence

The audit is an evidence exercise. If collecting evidence is a fire drill, the audit will be too.

- ☐ You know which evidence each control requires.
- ☐ Evidence is collected automatically where possible, not screenshotted by hand the week before.
- ☐ Evidence accumulates continuously across the audit period, not just on the day you remember.
- ☐ Evidence is organized and mapped to the controls it supports.

7. People and incident response

- ☐ Staff complete security awareness training, and you keep the records.
- ☐ You have a written incident response plan that names who does what.
- ☐ You have actually walked through the plan, even once, rather than only writing it.
- ☐ For HIPAA: you have signed business associate agreements with every vendor that touches protected health information.
- ☐ Vendors with access to your data have been risk assessed.

How to read your result

Count your Partial and Nos. Each one is real work, but most are smaller than they look once they are written down and owned. The pattern that gets organizations in trouble is not having gaps. It is not knowing where the gaps are until the audit, the customer questionnaire, or the regulator forces the issue.

If you want a hand turning this list into a finished program, that is exactly what I do: the policies written to how you run, the controls implemented in your cloud as code, and the evidence package the auditor signs off on.

Graham Brooks, CISSP | Brooks Security LLC

Talk through your compliance project at [**brooks-security.com/docs/services/compliance-program/**](https://brooks-security.com/docs/services/compliance-program/)